PLANNER-PRO

OPERATING SYSTEM DE PRODUCTIVITÉ & INGÉNIERIE

SPÉCIFICATION TECHNIQUE V2.2

INGÉNIERIE DES SYSTÈMES & ARCHITECTURE LOGICIELLE

Dossier d'Architecture Technique (DAT)

Guide d'implémentation industrielle complet : modélisation C4 des conteneurs, protocoles cryptographiques d'invitations CSPRNG/SHA-256, graphe acyclique Gantt (DFS), Time-Tracking temps réel multi-nœuds, moteur prédictif heuristique et synchronisation asynchrone Transactional Outbox vers Google Cloud Firestore.

01. PLANIFICATION

Gantt & Kanban

Graphe acyclique orienté (DAG) vérifié par parcours DFS récursif en O(V+E).

02. TEMPS RÉEL

Sockets & Timers

Passerelle WSS Socket.io couplée à un adaptateur Pub/Sub distribué Redis 7.

03. SÉCURITÉ

RBAC & Crypto

Chiffrement symétrique AES-256-GCM et matrice d'habilitations à 2 niveaux.

04. RÉSILIENCE

Transactional Outbox

Élimination du problème du double-write par découplage asynchrone MySQL/Firestore.

ÉDITEUR & PLATEFORME

Boukarou OS • R&D

ENVIRONNEMENT CIBLE

Docker • Durcissement sécurité en cours

DATE DE RÉVISION

Octobre 2026

CLASSIFICATION

Spécification Interne

Sommaire Exécutif & Table des Matières

1. Vision Architecturale & Principes Directeurs
2. Architecture Globale des Conteneurs (Modèle C4 Niveau 2)
3. Authentification, Chiffrement Symétrique & Matrice RBAC
4. Protocole Cryptographique des Invitations & Adhésion
5. Moteur Kanban & Algorithme Acyclique Gantt (DFS)
6. Time-Tracking & Passerelle WebSockets Temps Réel
7. Calendrier Interactif & Algorithme de Time-Blocking
8. Bloc-notes Intelligent & Moteur Lexical (Notes-to-Tasks)
9. Moteur Financier, Budgets & Burn Rate Projet
10. Synchronisation Hybride Asynchrone : Transactional Outbox vers Cloud Firestore
11. Moteur d'IA & Heuristique Prédictive (Copilot & Gemini)
12. Gouvernance, Traçabilité & Journal d'Audit (Audit Trail)
13. Passerelle de Notifications Temps Réel & Mentions
14. Infrastructure de Production, Déploiement & Résilience
15. Sécurité Applicative & Programme de Remédiation

1. Vision Architecturale & Principes Directeurs

1.1 Contexte & Paradigme "Focus & Flow"

Planner-Pro transcende le simple gestionnaire de tâches pour devenir un hub actif de productivité profonde. L'application fait converger la réflexion (bloc-notes libre), la planification (Kanban, Gantt & Sprints) et l'exécution (Time-tracking temps réel et time-blocking calendrier) sans friction cognitive.

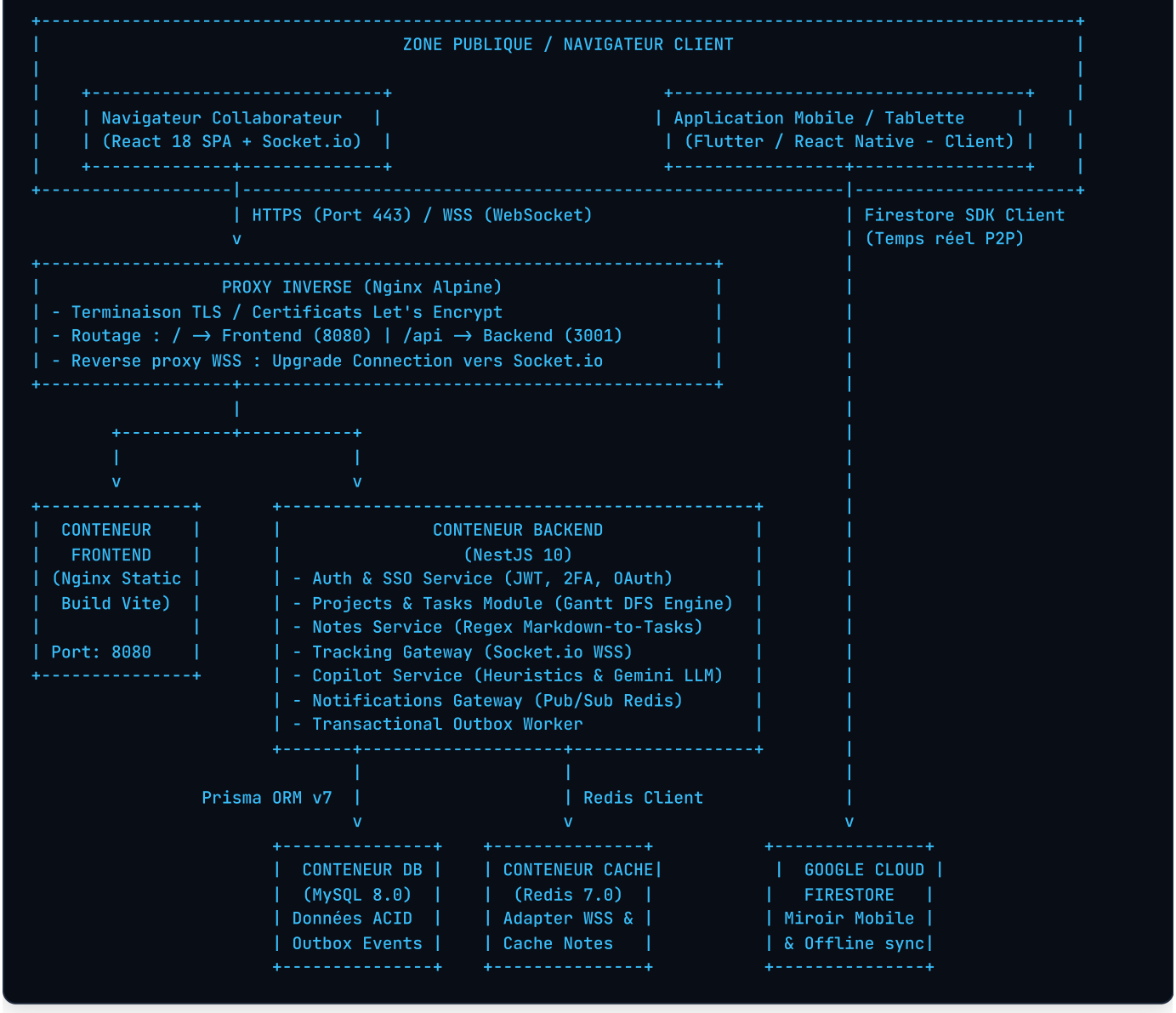
1.2 Principes d'Ingénierie Logicielle

- **Architecture Modulaire DDD (Domain-Driven Design)** : Découpage strict du backend NestJS en domaines d'affaires autonomes (`auth`, `projects`, `tracking`, `notes`, `notifications`, `firestore-sync`, `admin`).
- **Zéro Dépendance Circulaire Métier & Graphe Acyclique Dirigé (DAG)** : Les dépendances de tâches sont modélisées mathématiquement comme un DAG vérifié par recherche en profondeur (DFS).
- **Sécurité Défensive & Zéro Exposition** : Tout secret externe est chiffré symétriquement en AES-256-GCM. Aucun token brut d'invitation n'est persistant en base de données.
- **Résilience aux Pannes Réseau (Double-Write Problem résolu)** : L'intégration avec des services externes ou Cloud distants (comme Firestore) n'utilise jamais d'appel synchrone dans la transaction métier, mais s'appuie sur le patron *Transactional Outbox*.
- **Typage de bout en bout** : Monorepo TypeScript strict avec validation de runtime (Pipes `class-validator`, Zod/Typesafe Prisma Client).

2. Architecture Globale des Conteneurs (Modèle C4 Niveau 2)

Le système est conteneurisé et orchestré via Docker Compose, séparant hermétiquement les couches de présentation, de traitement d'affaires et de persistance.

ARCHITECTURE



2.1 Description Technique des Conteneurs

Conteneur 1 : Proxy Inverse Nginx (`ekose-nginx-1` ou Nginx Hôte)

- **Fonctions** : Terminaison TLS (Certificats RSA 4096 / ECDSA Let's Encrypt), négociation HTTP/2, compression Gzip/Brotli, rate-limiting (60 req/min sur endpoints sensibles), et négociation du tunnel WebSocket (`proxy_set_header Upgrade $http_upgrade; proxy_set_header Connection "upgrade"`).
- **Réseau** : Expose le port 80 (redirection permanente HTTP 301 vers 443) et le port 443.

Conteneur 2 : Frontend SPA (`planner-pro-production-frontend-1`)

- **Framework & Build** : React 18, TypeScript, bundler Vite.

- **Moteurs de rendu & Interaction** : `@dnd-kit/core` et `@dnd-kit/sortable` pour le glisser-déposer haute vélocité (Kanban, Calendrier, Sprints), Lucide React pour l'iconographie, Context API (`AppContext`) pour la distribution réactive de l'état global.
- **Serveur interne** : Nginx 1.27 Alpine servant les assets statiques compilés avec politique de cache agressive (`Cache-Control: public, max-age=31536000, immutable` pour les chunks hashés et `no-cache` pour `index.html`).

Conteneur 3 : Backend API NestJS (`planner-pro-production-backend-1`)

- **Framework & Moteur** : Node.js 20 LTS, NestJS 10, architecture modulaire en injection de dépendances.
- **Passerelle Temps Réel** : `@nestjs/websockets` avec moteur Socket.io v4. Couplé à `@socket.io/redis-adapter` pour permettre un dimensionnement horizontal multi-instances sans perte de cohésion de sessions.
- **Couche d'Accès aux Données** : Prisma ORM v7 avec découpage multi-fichiers de schéma (`auth.prisma` , `project.prisma` , `tracking.prisma` , `notes.prisma`). Pool de connexions optimisé avec timeouts stricts.

Conteneur 4 : Base de Données Principale (`planner-pro-production-db-1`)

- **Moteur SGBDR** : MySQL 8.0 Community Edition configuré en encodage `utf8mb4_unicode_ci` .
- **Garanties** : Moteur InnoDB, transactions au niveau d'isolation `READ COMMITTED` , clés étrangères avec cascades contrôlées, indexation B-Tree sur les identifiants de partitionnement métier (`workspaceId` , `projectId` , `userId`).

Conteneur 5 : Cache & Pub/Sub Distribué (`planner-pro-production-cache-1`)

- **Moteur** : Redis 7.0 Alpine.
- **Utilisations** :
  1. Adaptateur Pub/Sub pour la diffusion de messages WebSocket entre workers Node.js.
  2. Cache à faible latence pour la lecture des notes (`TTL: 3600s`).
  3. Stockage volatile des états de présence et timers actifs en cours de session.

Conteneur 6 : Cloud Firestore (Google Cloud Platform)

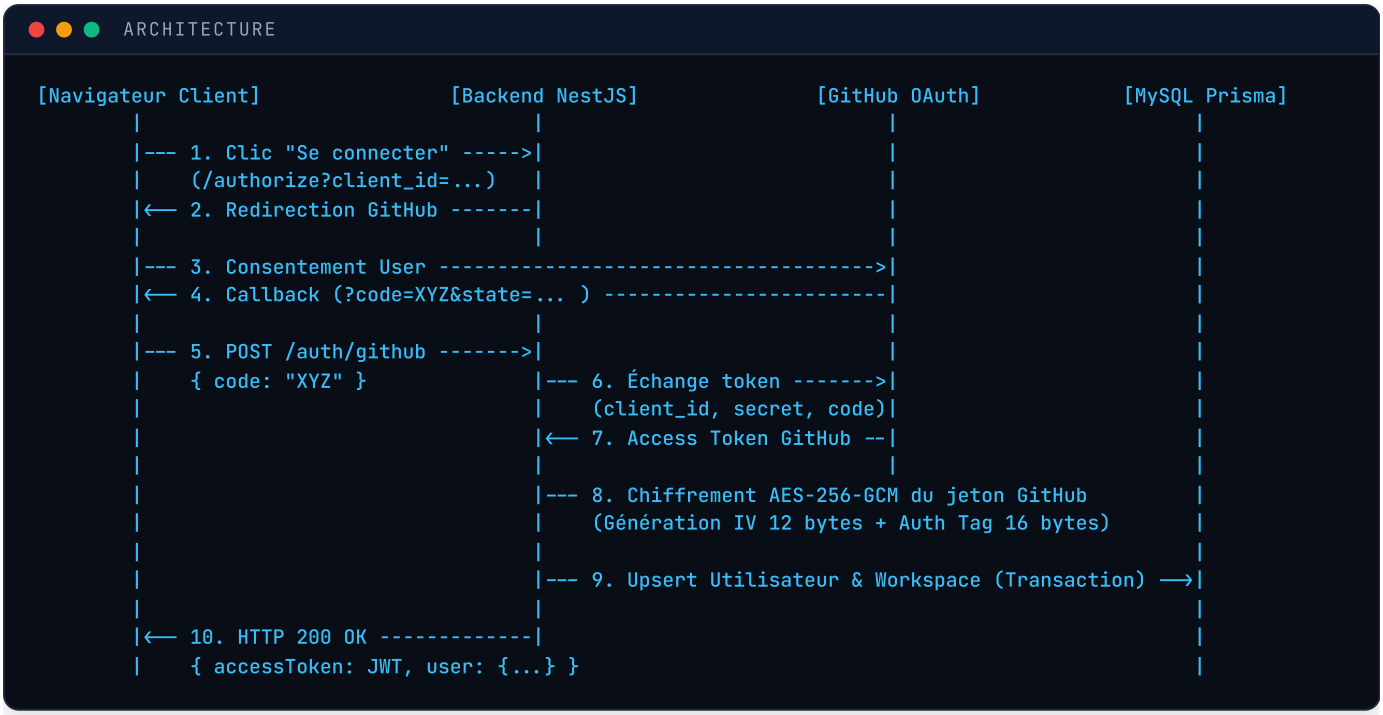
- **Rôle** : Base de données NoSQL distribuée servant de miroir temps réel pour les applications mobiles et de secours hors-ligne (Offline-First sync). Alimenté de manière asynchrone et idempotente par le worker *Transactional Outbox* du backend.

---

3. Authentification, Chiffrement Symétrique & Matrice RBAC

3.1 Protocole d'Authentification OAuth 2.0 GitHub & SSO

Le flux d'authentification OAuth 2.0 s'exécute selon la spécification RFC 6749 :



3.1.1 Typage des Jetons & Second Facteur (MFA)

Depuis la Phase 0 du programme de sécurité (constat S3), chaque jeton émis par le `TokenService` (`backend/src/auth/token.service.ts`) porte un claim `typ` explicite :

- **Jeton d'accès** : `typ: "access"`. Seul ce type est accepté par le guard HTTP (`jwt.guard.ts`) et par le handshake des passerelles WebSocket.
- **Ticket MFA** : `typ: "mfa_ticket"`, audience `mfa-challenge`, signé avec une clé dédiée dérivée par HKDF de `JWT_SECRET`. Il n'est accepté que sur `POST /auth/mfa/challenge`, il est **à usage unique** (consommation atomique dans Redis) et limité à **5 essais**.
- **Conséquence de migration** : les jetons émis avant ce changement (sans `typ`) sont rejetés ; tous les utilisateurs doivent se reconnecter une fois après le déploiement.

3.1.2 SSO d'Entreprise & Provisioning SCIM

- **Interrupteurs de fonctionnalité** : le SSO et le SCIM sont désactivés par défaut (`FEATURE_SSO_ENABLED=false`, `FEATURE_SCIM_ENABLED=false`). Désactivées, leurs routes répondent 404 avant toute authentification et l'onglet SSO est masqué sur l'écran de connexion. L'état est exposé au frontend par la route publique `GET /features`.
- **Fournisseurs SSO** : seuls les fournisseurs réellement implémentés sont acceptés par le DTO. Les fournisseurs `SAML2` et `OIDC_GENERIC` répondent 501 tant qu'aucune vérification d'assertion n'existe ; les configurations existantes de ce type sont désactivées par migration.
- **Isolation SCIM** : une clé SCIM n'agit que sur son propre workspace. Elle ne modifie jamais l'e-mail ni le statut global d'un utilisateur (création sur un e-mail existant → 409, changement d'e-mail → 400) ; une désactivation (`active=false`) retire uniquement l'adhésion au workspace. Le nom n'est modifiable que pour les comptes provisionnés par ce workspace (`User.provisionedByWorkspaceId`), et la révocation d'une clé est filtrée par workspace.

3.2 Spécification du Chiffrement Symétrique AES-256-GCM

Pour sécuriser les jetons d'accès tiers (GitHub personal tokens, jetons d'intégration Google Calendar, etc.), le service `encryption.util.ts` implémente un chiffrement symétrique authentifié **AES-256-GCM** (Galois/Counter Mode) :

- **Génération de la clé** : Clé symétrique de 256 bits dérivée de la variable d'environnement `ENCRYPTION_KEY`.

- **Vecteur d'Initialisation (IV)** : 12 octets pseudo-aléatoires cryptographiques (`crypto.randomBytes(12)`), unique par opération de chiffrement.
- **Tag d'Authentification (Auth Tag)** : 16 octets générés par l'algorithme GCM, garantissant l'intégrité et la non-altération du payload chiffré.
- **Format de sérialisation en base** : `::` . Toute tentative de falsification du ciphertext provoque le rejet immédiat du déchiffrement (`CipherJobException`).

3.3 Matrice des Permissions RBAC à Deux Niveaux

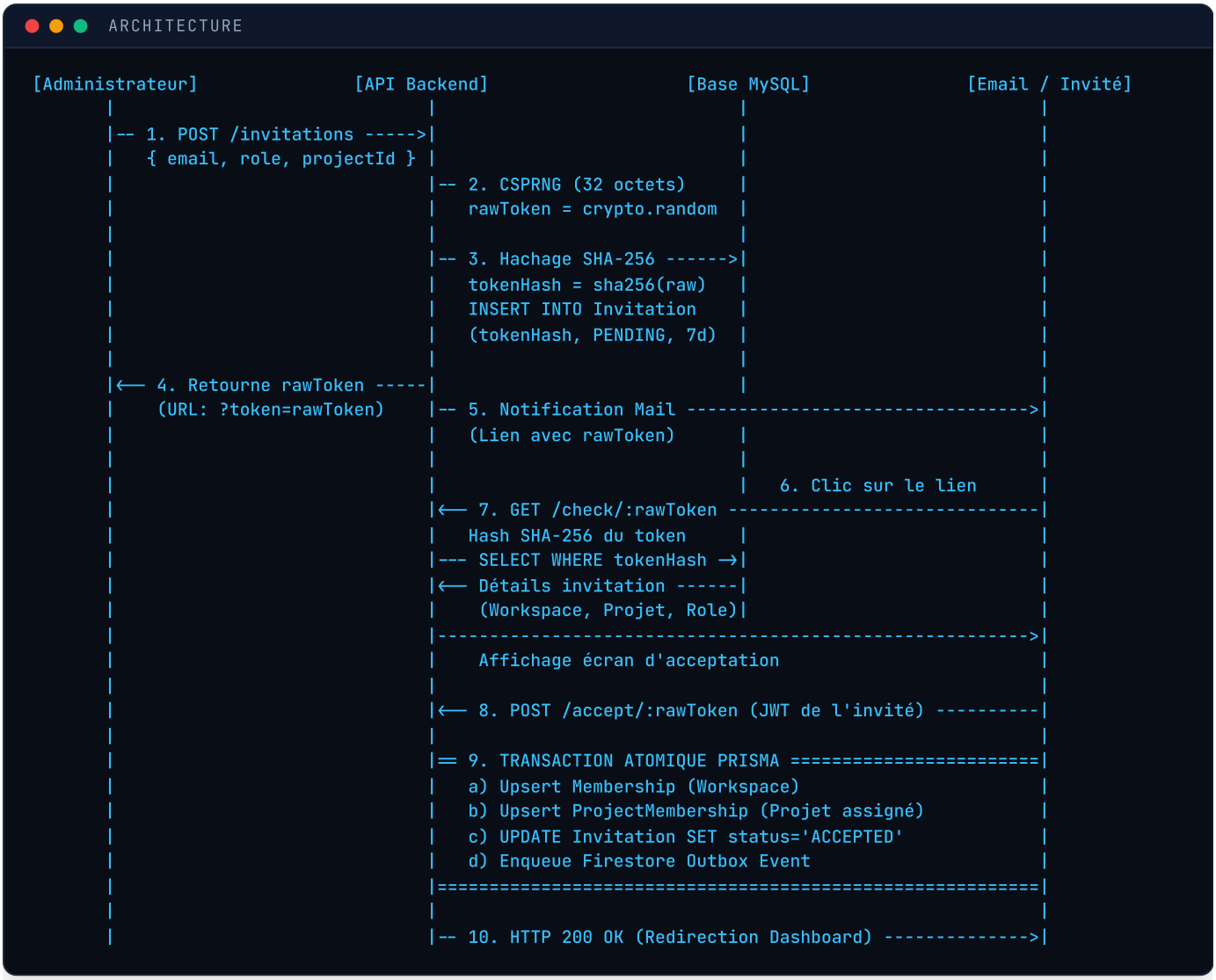
Planner-Pro sépare la gouvernance de l'organisation générale (Niveau Workspace) de la gouvernance opérationnelle d'un projet spécifique (Niveau Projet).

ARCHITECTURE

```
================================================================================================================
                                MATRICE DES HABILITATIONS WORKSPACE & PROJET
================================================================================================================
Capacité Technique / Fonctionnelle          | OWNER | ADMIN | MEMBER | VIEWER | MANAGER | CONTRIBUTOR | CLIENT
--------------------------------------------+-------+-------+--------+--------+---------+-------------+-------
Supprimer ou renommer l'Espace de travail   |  OUI  |  NON  |  NON   |  NON   |    -    |      -      |   -
Gérer les intégrations & Webhooks globaux   |  OUI  |  OUI  |  NON   |  NON   |    -    |      -      |   -
Inviter un membre au niveau Espace          |  OUI  |  OUI  |  NON   |  NON   |    -    |      -      |   -
Créer un nouveau projet                     |  OUI  |  OUI  |  OUI   |  NON   |    -    |      -      |   -
Modifier les paramètres / Clôturer Projet   |  OUI* |  OUI* |   -    |   -    |   OUI   |     NON     |  NON
Créer, éditer, déplacer des tâches          |  OUI* |  OUI* |   -    |   -    |   OUI   |     OUI     |  NON
Lancer un chronomètre (Time-Tracking)       |  OUI* |  OUI* |   -    |   -    |   OUI   |     OUI     |  NON
Modifier les taux horaires & finances       |  OUI  |  OUI  |  NON   |  NON   |   OUI   |     NON     |  NON
Consulter les rapports financiers & marge   |  OUI  |  OUI  |  NON   |  NON   |   OUI   |     NON     |  NON
Commenter une tâche                         |  OUI  |  OUI  |  OUI   |  NON   |   OUI   |     OUI     |  OUI
Consulter le projet en lecture seule        |  OUI  |  OUI  |  OUI   |  OUI   |   OUI   |     OUI     |  OUI
================================================================================================================
* Note : Les rôles Workspace OWNER et ADMIN héritent implicitement de tous les droits MANAGER sur
l'ensemble des sous-projets de leur espace via le guard `assertProjectRole()`.
```

4. Protocole Cryptographique des Invitations & Adhésion

Le système d'invitation garantit qu'aucun lien d'invitation ne puisse être deviné, falsifié ou récupéré en cas de fuite de base de données.



4.1 Détails Techniques de Sécurité

1. **Entropie Cryptographique** : Le jeton brut `rawToken` est généré par `crypto.randomBytes(32).toString('hex')`, offrant un espace d'états de 2^{256}, éliminant tout risque d'attaque par force brute ou collision.

2. **Hachage Unidirectionnel en Base** : Seul le digest `crypto.createHash('sha256').update(rawToken).digest('hex')` est stocké en base de données. Même avec un accès administrateur direct à la table MySQL `invitations`, un attaquant ne peut pas reconstituer le lien magique à présenter à l'API.

3. **Idempotence & Anti-Replay** : Dès qu'une invitation est consommée via l'endpoint `/projects/invitations/accept/:token`, son statut est basculé à `ACCEPTED` avec horodatage `acceptedAt = NOW()`. Toute tentative ultérieure de réutilisation est immédiatement rejetée avec une exception HTTP 400 (`Cette invitation a déjà été acceptée`).

---

5. Moteur Kanban & Algorithme Acyclique Gantt (DFS)

5.1 Machine à États Finis du Cycle de Vie d'une Tâche

Une tâche transite entre six états stricts :

ARCHITECTURE



5.2 Algorithme de Détection de Cycles dans le Graphe de Dépendances (DFS)

Dans un diagramme de Gantt, si la Tâche A dépend de la Tâche B, et la Tâche B dépend de la Tâche C, ajouter une dépendance de C vers A créerait une boucle infinie ($A \to B \to C \to A$) rendant impossible tout calcul de planification ou de dates critiques.

L'algorithme implémenté dans dependencies.service.ts utilise une recherche récursive en profondeur (**Depth-First Search - DFS**) avec mémorisation des sommets visités :

TYPESCRIPT

```typescript
/**
 * Recherche récursive DFS de chemin orienté entre deux sommets.
 * Complexité algorithmique : O(V + E) où V = sommets (tasks), E = arêtes (dependencies)
 */
private async hasPath(
  startTaskId: string,
  targetTaskId: string,
  visited: Set<string>,
): Promise<boolean> {
  // Condition d'arrêt 1 : Le chemin boucle sur le sommet cible (Cycle détecté)
  if (startTaskId === targetTaskId) return true;

  // Condition d'arrêt 2 : Branche déjà explorée sans succès (Évite de revisiter un sous-graphe)
  if (visited.has(startTaskId)) return false;
  visited.add(startTaskId);

  // Récupérer toutes les arêtes sortantes : tâches dont dépend startTaskId
  const dependencies = await this.prisma.taskDependency.findMany({
    where: { taskId: startTaskId },
    select: { dependsOnTaskId: true },
  });

  // Exploration en profondeur de chaque successeur
  for (const dep of dependencies) {
    if (await this.hasPath(dep.dependsOnTaskId, targetTaskId, visited)) {
      return true;
    }
  }

  return false;
}
```

- **Validation à l'insertion** : Avant d'insérer `(taskId, dependsOnTaskId)`, le service appelle `hasPath(dependsOnTaskId, taskId, new Set())`. Si un chemin existe déjà dans le sens inverse, l'insertion est immédiatement bloquée avec une erreur HTTP 400 : `"A cyclic dependency was detected. Task X cannot depend on Task Y"`.

---

6. Time-Tracking & Passerelle WebSockets Temps Réel

Le suivi du temps de travail s'appuie sur une architecture hybride combinant la précision d'une passerelle WebSocket bidirectionnelle et la robustesse de la persistance relationnelle.

ARCHITECTURE



6.1 Protocole & Gestion des Événements Temps Réel

- **Isolation des Salons (Rooms)** : À la connexion, le client rejoint automatiquement :

  1. Son salon personnel `user:${userId}` (pour synchroniser le chronomètre sur plusieurs onglets ou appareils de ce collaborateur).

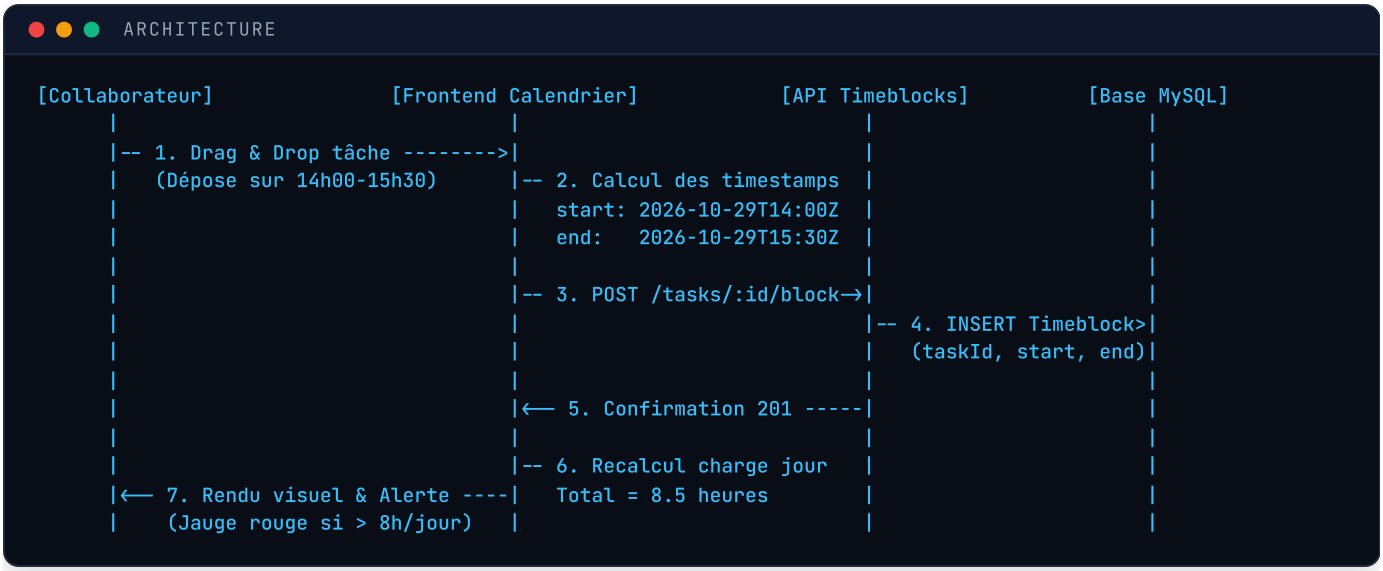
  2. Les salons de ses espaces `workspace:${workspaceId}` (pour notifier les collègues en temps réel de qui travaille sur quoi).

- **Adaptateur Distribué Redis** : Grâce à `@socket.io/redis-adapter`, si le backend est dimensionné sur 3 conteneurs distincts, un événement de démarrage de tracking émis sur le serveur A est instantanément relayé par Redis aux clients connectés sur les serveurs B et C.

---

7. Calendrier Interactif & Algorithme de Time-Blocking

Le module de calendrier concrétise la planification dans le temps réel en découpant la journée en créneaux bloqués (*Timeblocks*).



7.1 Algorithme de Détection de Surcharge Quotidienne

Lors de chaque modification de timeblock, le frontend et le backend exécutent le calcul de la somme des durées de tous les blocs d'un utilisateur sur la journée J :

$$\text{Charge}(J) = \sum_{i \in \text{Timeblocks}(J)} (\text{endTime}_i - \text{startTime}_i)$$

- **Seuil Vert** : $\text{Charge}(J) \le 6\,\text{heures}$ (Capacité optimale de concentration).
- **Seuil Orange** : $6\,\text{heures} < \text{Charge}(J) \le 8\,\text{heures}$ (Journée pleine).
- **Seuil Rouge & Alerte Critique** : $\text{Charge}(J) > 8\,\text{heures}$ (Risque avéré de surmenage / surcharge cognitive).

7.2 Intégrations de Calendrier Externes

Le simulateur de calendrier et les jetons OAuth factices (`mock-*`) ont été supprimés (constat S5). Le comportement est désormais uniquement réel :

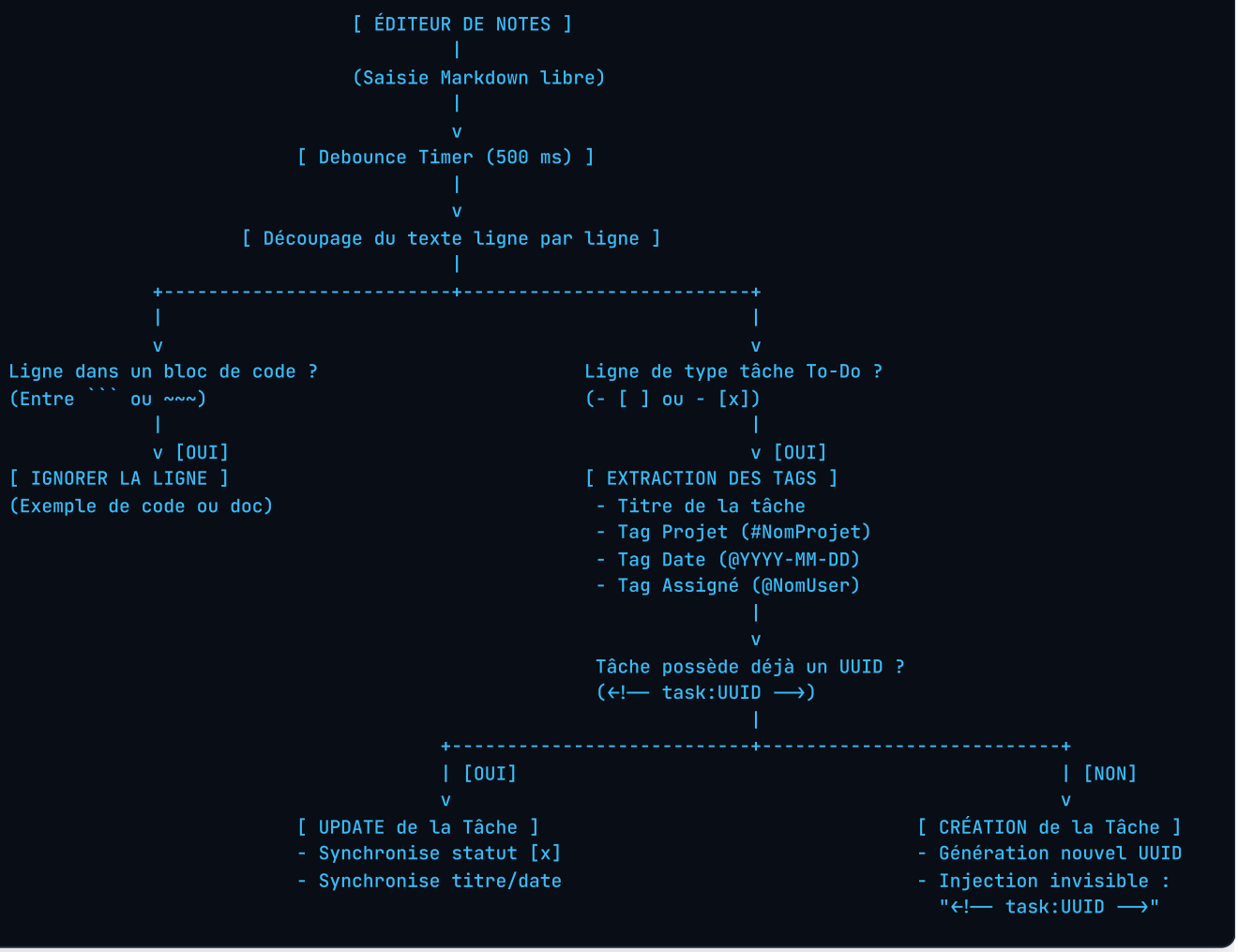
- **Sans identifiants OAuth configurés**, les routes d'intégration répondent 503, quel que soit `NODE_ENV` , et l'interface affiche « Non configuré » (constat P1).
- **Synchronisation et export** sont réservés aux rôles OWNER/ADMIN ; la tâche de synchronisation est rattachée à l'utilisateur appelant. Une synchronisation sans intégration renvoie `skipped: NOT_CONFIGURED` , un export sans intégration connectée renvoie 400.
- **Cloisonnement** : une intégration n'est chargée que si elle appartient au workspace de l'appelant (sinon 404, avant tout appel sortant), et les réponses de l'API ne contiennent jamais les jetons OAuth (constat S14, étape 1).
- **Données héritées** : le script `backend/scripts/cleanup-simulated-calendar.ts` identifie les événements simulés importés auparavant et réattribue au propriétaire du workspace les tâches de synchronisation détenues par un non-membre (mode rapport par défaut, action uniquement avec `--apply`).

---

8. Bloc-notes Intelligent & Moteur Lexical (Notes-to-Tasks)

L'éditeur de notes permet une rédaction continue en Markdown. Le moteur d'analyse lexicale en arrière-plan convertit les intentions écrites en tickets de projet réels sans interrompre la saisie.

ARCHITECTURE



8.1 Expressions Régulières & Préservation Lexicale

Le service notes.service.ts utilise des patterns stricts :

1. **Détection de case à cocher** : `/^(\s-\s\[([ xX])\])\s+(.*)$/`
2. **Extraction du tag de projet** : `/#([a-zA-Z0-9_\-]+)/`
3. **Extraction de la date d'échéance** : `/@(\d{4}-\d{2}-\d{2})/`
4. **Marqueur d'idempotence masqué** : `<!— task:UUID —>`

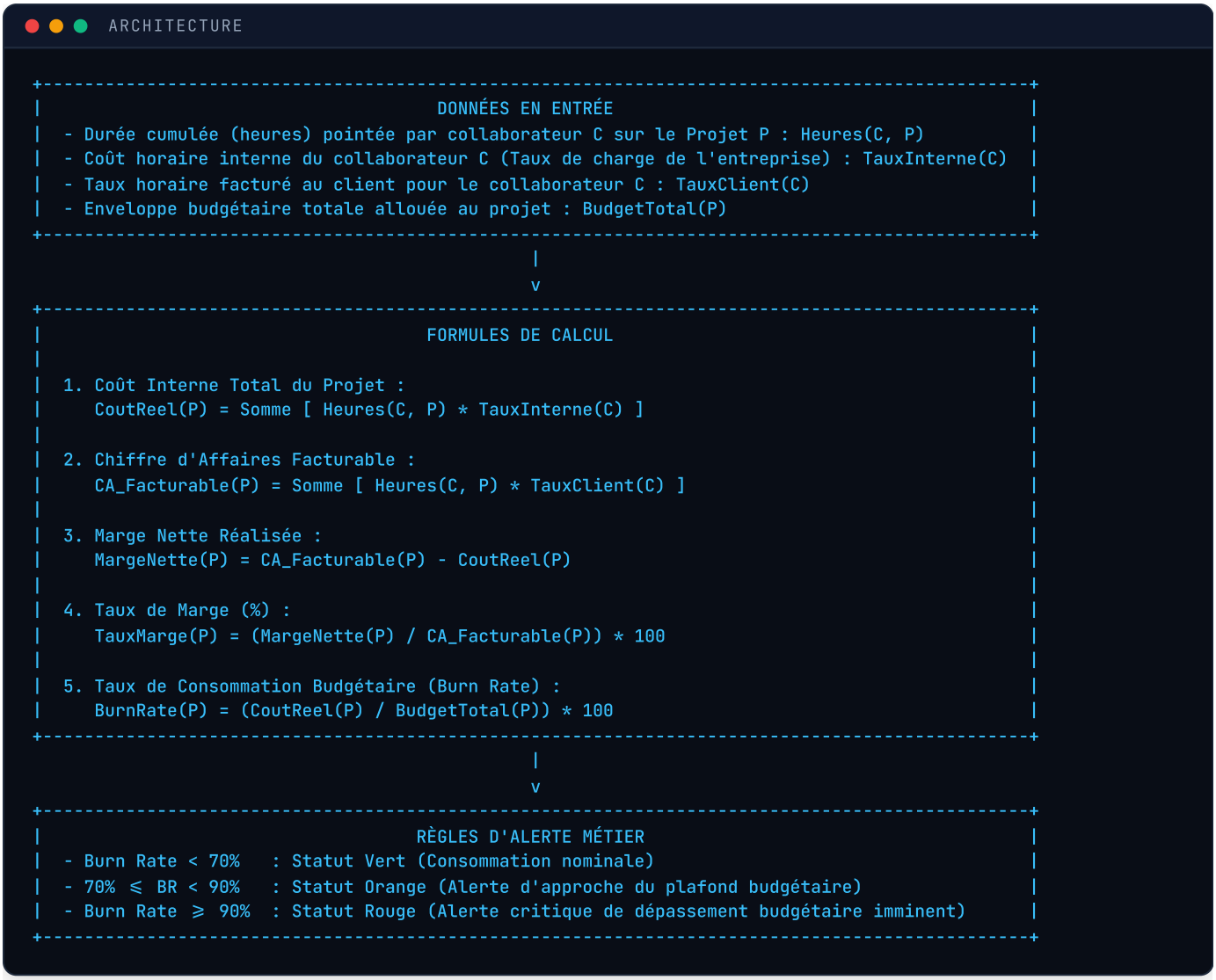
- **Idempotence garantie** : En insérant le commentaire HTML masqué `<!— task:UUID —>` en fin de ligne Markdown, le texte reste parfaitement lisible pour l'utilisateur, tout en fournissant au moteur un identifiant déterministe pour synchroniser bidirectionnellement la case cochée et le statut Kanban de la tâche.

---

9. Moteur Financier, Budgets & Burn Rate Projet

Pour chaque projet, Planner-Pro croise les heures pointées issues du module Time-Tracking avec la grille tarifaire des collaborateurs pour dériver les métriques de rentabilité en temps réel.

ARCHITECTURE



10. Synchronisation Hybride Asynchrone : Transactional Outbox vers Cloud Firestore

10.1 Problématique du Double-Write

Lorsqu'une entité (ex. une Tâche ou une Invitation) est créée, mettre à jour MySQL et appeler simultanément l'API distante Google Firestore expose l'architecture à des incohérences majeures si l'appel réseau vers Firestore échoue ou subit un timeout après que la transaction MySQL a été validée (commit).

10.2 Implémentation du Transactional Outbox Pattern

Pour éliminer ce problème, Planner-Pro applique le patron **Transactional Outbox** :

ARCHITECTURE

```
[Requête Utilisateur]
         |
         v
+-------------------------------------------------------------------------------------+
|                    TRANSACTION ATOMIQUE MYSQL (prisma.$transaction)                 |
|                                                                                     |
|  1. Écriture métier : INSERT INTO Task (...)                                        |
|  2. Enregistrement d'événement :                                                    |
|     INSERT INTO FirestoreSyncOutbox (                                               |
|       id, sequence, entityType, entityId, workspaceId, operation, payload, attempts |
|     ) VALUES (                                                                      |
|       UUID(), AUTO_INCREMENT, 'task', 'task-123', 'ws-456', 'upsert', JSON, 0       |
|     )                                                                               |
+-------------------------------------------------------------------------------------+
         |
         v (Transaction validée avec succès dans MySQL)
+-------------------------------------------------------------------------------------+
|                      WORKER D'ARRIÈRE-PLAN (FirestoreSyncService)                   |
|                                                                                     |
|  1. Boucle de polling / Cron périodique :                                           |
|     SELECT * FROM FirestoreSyncOutbox                                               |
|     WHERE processedAt IS NULL AND (leasedAt IS NULL OR leasedAt < NOW() - 60s)      |
|     ORDER BY sequence ASC LIMIT 25                                                  |
|                                                                                     |
|  2. Prise de bail (Locking distribué) : UPDATE SET leasedAt = NOW()                 |
|                                                                                     |
|  3. Écriture par lot dans Firestore SDK :                                           |
|     const batch = firestore.batch();                                               |
|     batch.set(firestore.doc(...), payload);                                         |
|     await batch.commit();                                                           |
|                                                                                     |
|  4. Acquittement réussi :                                                           |
|     UPDATE FirestoreSyncOutbox SET processedAt = NOW()                              |
|                                                                                     |
|  5. En cas d'échec :                                                                |
|     UPDATE FirestoreSyncOutbox SET attempts = attempts + 1, lastError = err         |
|     (Retry avec backoff exponentiel jusqu'à 10 tentatives max)                      |
+-------------------------------------------------------------------------------------+
```

- **Purge automatique** : Un job planifié quotidien supprime automatiquement les événements de l'outbox dont le traitement (`processedAt`) remonte à plus de 7 jours, conservant une table légère et hautement performante.

---

11. Moteur d'IA & Heuristique Prédictive (Copilot & Gemini)

Le service copilot.service.ts combine un moteur de règles déterministes d'analyse des risques avec la puissance de synthèse d'un Grand Modèle de Langage (Google Gemini 1.5 Pro).

ARCHITECTURE



11.1 Algorithmes de Détection Prédictive des Risques

1. **Règle OVERDUE** : Identifie toute tâche active dont la date limite (`dueDate`) est strictement antérieure à la date courante ($D_{\text{due}} < D_{\text{today}}$). Classée avec sévérité `CRITICAL`.

2. **Règle AT_RISK** : Identifie les tâches dont l'échéance arrive dans un délai de 3 jours ($0 \le D_{\text{due}} - D_{\text{today}} \le 3\,\text{jours}$) alors que le statut est resté à l'état `TODO`. Classée en sévérité `HIGH`.

3. **Règle BOTTLENECK (Goulot d'Étranglement)** : Parcourt le graphe des dépendances de chaque tâche. Si une tâche dépend d'une tâche identifiée comme `OVERDUE` ou `AT_RISK`, elle hérite d'une alerte de blocage immédiate.

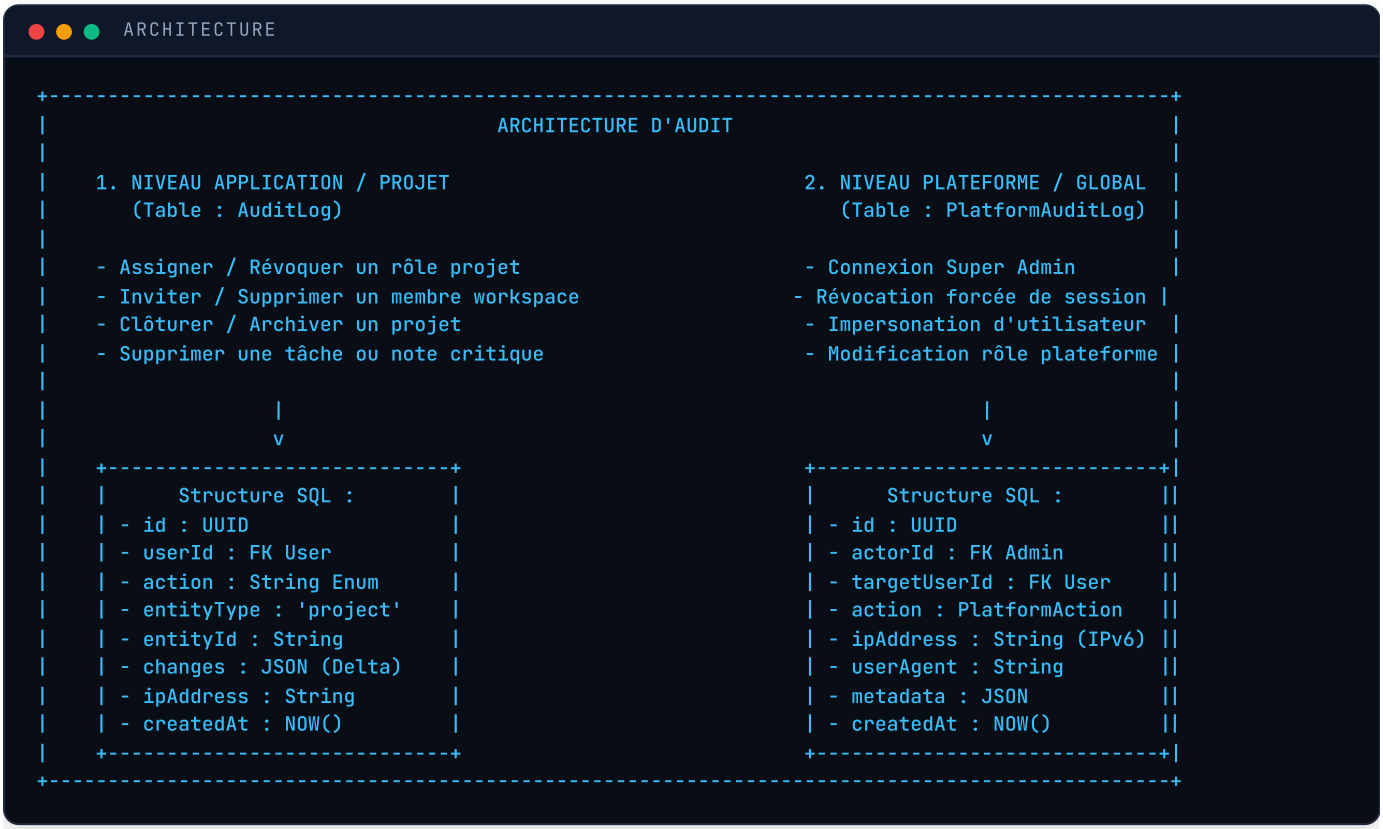
4. **Règle OVERLOADED** : Croise les assignations de tâches actives avec les profils de capacité `ResourceProfile` (ex: 35h/semaine). Si le cumul des temps estimés dépasse le seuil de tolérance de 110%, le collaborateur est marqué en surcharge.

11.2 Résilience & Fallback Déterministe

Si l'appel à l'API Gemini échoue (coupure réseau, quota API atteint ou timeout de 8 secondes), le système bascule automatiquement et de manière transparente sur une synthèse algorithmique déterministe, garantissant que l'utilisateur reçoit toujours son briefing quotidien sans interruption de service.

12. Gouvernance, Traçabilité & Journal d'Audit (Audit Trail)

La conformité réglementaire (RGPD, SOC2) et la sécurité opérationnelle imposent une non-répudiation totale des actions d'administration et de gestion des droits. Planner-Pro implémente un double niveau d'audit persistant et immuable.



12.1 Format des Deltas de Données (JSON Diffing)

Chaque entrée d'audit conserve l'état avant et après modification dans le champ `changes` sous forme de JSON strict :

```json
{
  "entity": "ProjectMembership",
  "operation": "ROLE_UPDATE",
  "previous": { "role": "CONTRIBUTOR" },
  "current": { "role": "MANAGER" },
  "grantedBy": "user-uuid-sarah-connor",
  "timestamp": "2026-10-29T21:05:00.000Z"
}
```

- **Immutabilité** : Aucun endpoint d'API n'autorise de `DELETE` ou de `UPDATE` sur les tables `AuditLog` et `PlatformAuditLog`. Les enregistrements sont en écriture seule (*Append-Only*).

13. Passerelle de Notifications Temps Réel & Mentions

La passerelle notifications.gateway.ts distribue les événements d'équipe en temps réel sur les postes des collaborateurs via WebSockets et WebSocket Pub/Sub Redis.

ARCHITECTURE

```
[ Événement Métier ] (Ex: Assignation de tâche, Commentaire avec @mention, Jalon atteint)
         |
         v
+-------------------------------------------------------------------------------------+
|                       SERVICE DE NOTIFICATIONS (NestJS)                             |
|                                                                                     |
|  1. Persistance en base de données :                                                |
|     INSERT INTO Notification (userId, title, message, type, read=false)             |
|                                                                                     |
|  2. Routage vers la passerelle WebSocket :                                          |
|     notificationsGateway.server.to(`user:${targetUserId}`).emit('notification', {   |
|       id, type, title, message, createdAt                                           |
|     });                                                                             |
|                                                                                     |
|  3. Si le collaborateur n'a pas de socket active :                                  |
|     Envoi asynchrone d'un email de notification (MailService / SMTP ou webhook n8n) |
+-------------------------------------------------------------------------------------+
         |
         +----------------------------------+
         |                                  |
         v                                  v
[ Collaborateur Connecté ]        [ Collaborateur Hors-Ligne ]
Toast In-App instantané           Notification Email différée
Badge de cloche incrémenté        avec lien direct vers la tâche
```

13.1 Parsing des Mentions & Événements Pris en Charge

- **Mentions dans les commentaires** : Analyse de pattern `@([a-zA-Z0-9._-]+)` lors de l'ajout d'un commentaire sur une tâche (`addComment`). Les utilisateurs mentionnés sont automatiquement extraits, validés quant à leur appartenance au projet, et notifiés.
- **Alertes de Dépendance Résolue** : Lorsqu'une tâche bloquante T_1 passe au statut `DONE` , le système identifie toutes les tâches T_2 dépendantes et notifie leurs responsables : *"La tâche bloquante T_1 a été complétée, vous pouvez démarrer T_2"*.

---

14. Infrastructure de Production, Déploiement & Résilience

14.1 Topologie des Conteneurs Docker

La stack est déployée sur une instance Cloud (Oracle Linux ARM64 / Ubuntu 24.04 LTS) selon la configuration définie dans docker-compose.prod.yml :

1. `planner-pro-production-backend` : Image Node.js 20 Alpine exécutant le binaire NestJS compilé (`127.0.0.1:3003 → 3001`).

2. `planner-pro-production-frontend` : Image Nginx Alpine servant l'application SPA React 18 (`127.0.0.1:8080 → 80`).

3. `planner-pro-production-db` : Serveur MySQL 8.0 avec volumes montés sur stockage persistant hôte (`/var/lib/mysql`).

4. `planner-pro-production-cache` : Serveur Redis 7.0 avec politique d'éviction mémoire `allkeys-lru` .

14.2 Stratégie de Sauvegarde & PRA (Plan de Reprise d'Activité)

- **Sauvegarde automatique** : Le script scripts/backup-production.sh effectue un dump cohérent de la base MySQL (`mysqldump --single-transaction --quick`), compresse l'archive avec `gzip` et chiffre le fichier résultant avec

OpenSSL avant synchronisation distante.

- **Healthcheck & Auto-Healing** : Tous les conteneurs sont configurés avec `restart: unless-stopped`. Les services `db` (`mysqladmin ping`) et `cache` (`redis-cli ping`) disposent d'une sonde de vitalité toutes les 10 secondes ; le backend et le frontend n'en ont pas encore. L'endpoint `/admin/health` exige un jeton d'administrateur et ne peut donc pas servir de sonde Docker.

14.3 Connexion Sécurisée à la Base de Données

- **Pilote** : Prisma utilise `@prisma/adapter-mariadb`, avec le pilote `mariadb` forcé en version `⩾3.5.4` par override pnpm (correction d'avis de sécurité, constat S4).
- **Configuration obligatoire** : hors `development` / `test`, le backend refuse de démarrer si `DATABASE_URL` est absent ; il n'existe plus de repli sur des identifiants par défaut.
- **Chiffrement** : TLS activé par `DATABASE_SSL=true` (autorité de certification optionnelle via `DATABASE_SSL_CA`). La récupération de clé publique MySQL (`allowPublicKeyRetrieval`) n'est autorisée qu'en développement et en test sans TLS ; une clé RSA épinglée (`DATABASE_RSA_PUBLIC_KEY`) est tolérée en développement et en staging.
- **Production** : TLS MySQL obligatoire. En production, le backend et `wait-for-db.js` refusent de démarrer sans `DATABASE_SSL=true`. Dans `docker-compose.prod.yml`, MySQL tourne avec `--require-secure-transport=ON` (connexions non chiffrées refusées) ; seul `ca.pem` est monté dans le backend. La CLI Prisma (`prisma.config.ts` via `backend/src/prisma/database-url.ts`) utilise aussi TLS et n'a plus de repli sur le compte `root`.
- **Certificats** : générés par `ops/mysql-tls/generate-certs.sh` dans `secrets/mysql/` (ignoré par Git), à exécuter **avant** le premier `docker compose up`. Rotation possible en conservant l'autorité de certification ; `ca-key.pem` ne doit pas rester sur l'hôte de production. Procédure : `docs/deployment-production.md`, section « TLS MySQL (obligatoire) ».
- **Développement local** : la CLI Prisma ne lit pas `.env` ; exporter `NODE_ENV=development` ou `DATABASE_URL` avant toute commande Prisma.

14.4 Variables d'Environnement de Sécurité

Variable	Valeur par défaut	Rôle
`FEATURE_SSO_ENABLED`	`false`	Active les routes et l'interface SSO
`FEATURE_SCIM_ENABLED`	`false`	Active les routes SCIM
`FEATURE_IMPERSONATION_ENABLED`	`false`	Active l'impersonation depuis la console admin (route 404 et bouton masqué sinon)
`DATABASE_SSL`	`false` en dev ; `true` **obligatoire en production**	Active TLS vers MySQL ; sans lui, le backend refuse de démarrer en production
`DATABASE_SSL_CA`	—	Chemin de l'autorité de certification MySQL
`DATABASE_RSA_PUBLIC_KEY`	—	Clé RSA épinglée (développement / staging uniquement)

15. Sécurité Applicative & Programme de Remédiation

Un audit d'architecture et de sécurité complet a été conduit en octobre 2026. Il recense **45 constats** (4 critiques, 30 majeurs, 11 mineurs) répartis en sécurité (S), architecture (A) et produit (P), et organise leur correction en sept phases.

- **Rapport d'audit (référence)** : `docs/security/rapport-audit.md` — chaque constat y porte un identifiant stable, sa sévérité (CVSS pour la sécurité), sa localisation, la remédiation attendue et son critère d'acceptation.
- **Journal de corrections** : `docs/security/journal-corrections.md` — chaque correctif y est tracé avec ses tests, puis revu dans le code par l'architecte (`VALIDÉ` , `À REPRENDRE` ou `REJETÉ`).

15.1 Phases du Programme

Phase	Périmètre	Constats	État
0	Urgences : SCIM, repli SSO, ticket MFA, connecteur MariaDB, calendrier simulé, reprise des données	S1, S2, S3, S4, S5, S28, P1, P3, S14 (étape 1), S18 (étape 0)	**Validée côté code** — reste à appliquer en exploitation (migrations, certificats TLS, scripts de reprise)
1	Authentification et sessions : MFA, sessions révocables, contrôles uniformes à la connexion, OAuth GitHub	A3, S7, S8, S6, S9, P6, S27	En cours
2	SSO et SCIM complets : validation OIDC, vérification DNS des domaines, durcissement SCIM	S10, S11	À venir — SSO et SCIM restent désactivés jusqu'à la fin de cette phase
3	Autorisation centralisée, IDOR, temps réel (Socket.IO)	A1, A2, A4, S12, S13, S14 (suite), S15, S16	À venir
4	Invitations, console d'administration	P4, S17, S18 (suite)	À venir
5	Durcissement : SSRF, XSS, en-têtes, DTO, limitation de débit, webhooks, dépendances, code mort	S19 à S26, A5, A6, A7, P5, P8	À venir
6	Journal d'audit, tests e2e, intégration continue, montée vers pnpm 10	A8, A9, P2, P7	À venir

15.2 Règles de Développement Issues du Programme

1. **Test d'abus d'abord** : tout correctif de sécurité commence par un test qui reproduit l'attaque et échoue sur le code vulnérable.

2. **Fonctionnalités d'entreprise désactivées par défaut** tant que leur modèle de menace n'est pas validé (interrupteurs `FEATURE_*`).

3. **Pas de simulation en production** : aucune donnée ou aucun jeton factice ne doit être écrit en base hors des fixtures de test.

4. **Reprises de données tracées** : les scripts de reprise fonctionnent en mode rapport par défaut, n'agissent qu'avec `--apply` , sont idempotents et exportent un CSV de ce qu'ils modifient. Ils ne sont **pas réversibles** : le retour arrière passe par une sauvegarde dont la restauration a été testée avant l'exécution (`docs/security/runbook-reprise-phase0.md`).

Résumé de Conformité pour les Équipes d'Ingénierie

Ce document constitue la **spécification technique de référence (v2.2)** de Planner-Pro. Tout développement futur, ajout d'API ou refactorisation doit impérativement respecter les règles de non-régression, les patterns d'idempotence et les matrices d'habilitation détaillés dans ce dossier.